

DOCUMENTO DE ABERTURA E ENCERRAMENTO

Ordem de Serviço - Laboratorio 03

Reducao da Superficie de Ataque

Equipe: Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato

Status: CONCLUIDA | Lynis Hardening Index = 69

1. Identificacao

Empresa	AmazonTech
Unidade	Gerencia de Infraestrutura e Seguranca da Informacao
Servidor	WEB-01 (MachadoPC) - Debian 13.6
Tipo	Auditoria, reducao de superficie, hardening e validacao
Data	30/07/2026
Equipe	Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato
Status da OS	CONCLUIDA

2. Problemas x Tratamento

Problema	Acao	Status
Servicos legados / sem justificativa	Disable e2scrub_reap e exim4	Resolvido
SSH com config padrao / ausente	Instalado + hardening (root no, X11 no)	Resolvido
Firewall inexistente/permissivo	UFW default deny + allow OpenSSH	Resolvido
Sem resposta automatica a brute-force	Fail2Ban jail sshd ativa	Resolvido
Sem monitoramento de integridade	AIDE baseline + deteccao validada	Resolvido
Sem auditoria de hardening	Lynis audit system (HI=69)	Resolvido

3. Evidencias principais

```
Terminal - Evidencia 1 - Inventario de servicos

root@MachadoPC:~# systemctl list-units --type=service --state=running --no-pager; echo '--- enabled ---'; systemctl list-unit-files --type=service --state=running --no-pager
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
cron.service                        loaded active running Regular background program processing daemon
dbus.service                        loaded active running D-Bus System Message Bus
fail2ban.service                    loaded active running Fail2Ban Service
getty@tty1.service                  loaded active running Getty on tty1
rsyslog.service                     loaded active running System Logging Service
ssh.service                         loaded active running OpenBSD Secure Shell server
systemd-journald.service             loaded active running Journal Service
systemd-logind.service               loaded active running User Login Management
systemd-udevd.service                loaded active running Rule-based Manager for Device Events and Files
user@0.service                       loaded active running User Manager for UID 0
user@1000.service                    loaded active running User Manager for UID 1000

Legend: LOAD    → Reflects whether the unit definition was properly loaded.
          ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
          SUB     → The low-level unit activation state, values depend on unit type.

11 loaded units listed.
--- enabled ---
UNIT FILE                                STATE    PRESET
cron.service                            enabled enabled
fail2ban.service                        enabled enabled
getty@.service                          enabled enabled
networking.service                     enabled enabled
rsyslog.service                         enabled enabled
ssh.service                            enabled enabled
sshd-keygen.service                     enabled enabled
systemd-pstore.service                  enabled enabled
... (saida truncada) ...
```

Figura - Evidencia 1 - Inventario de servicos

```

Terminal - Evidencia 4 - Hardening SSH

root@MachadoPC:~# systemctl status ssh --no-pager | head -22; echo '--- params ---'; grep -E '^(\PermitRootLogin|PasswordAuthentication|PubkeyAuthentication
• ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-07-30 18:32:00 -04; 38min ago
   Invocation: b9cf0b76d6f3453187c397ce4c662dc6
   Docs: man:sshd(8)
        man:sshd_config(5)
   Main PID: 5607 (sshd)
   Tasks: 1 (limit: 9353)
   Memory: 1.3M (peak: 2.3M)
   CPU: 49ms
   CGroup: /system.slice/ssh.service
           └─5607 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Jul 30 18:31:59 MachadoPC systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Jul 30 18:32:00 MachadoPC sshd[5607]: Server listening on 0.0.0.0 port 22.
Jul 30 18:32:00 MachadoPC sshd[5607]: Server listening on :: port 22.
Jul 30 18:32:00 MachadoPC systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
--- params ---
/etc/ssh/sshd_config:PermitRootLogin no
/etc/ssh/sshd_config:PubkeyAuthentication yes
/etc/ssh/sshd_config:PasswordAuthentication yes
/etc/ssh/sshd_config:X11Forwarding no
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:PermitRootLogin no
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:PasswordAuthentication yes
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:PubkeyAuthentication yes
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:X11Forwarding no
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:MaxAuthTries 3
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:AllowUsers machado carlos
... (saida truncada) ...

```

Figura - Evidencia 4 - Hardening SSH

```

Terminal - Evidencia 5 - Politica UFW (default deny + SSH)

root@MachadoPC:~# ufw status verbose; echo '--- numbered ---'; ufw status numbered
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp (OpenSSH) ALLOW IN Anywhere
22/tcp (OpenSSH (v6)) ALLOW IN Anywhere (v6)

--- numbered ---
Status: active

To Action From
--
[ 1] OpenSSH ALLOW IN Anywhere
[ 2] OpenSSH (v6) ALLOW IN Anywhere (v6)

```

Figura - Evidencia 5 - Politica UFW (default deny + SSH)

```
Terminal - Evidencia 6 - Fail2Ban jail sshd

root@MachadoPC:~# systemctl status fail2ban --no-pager | head -18; echo '--- client ---'; fail2ban-client status; fail2ban-client status sshd
• fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-07-30 18:32:38 -04; 37min ago
  Invocation: 6d2a70fce5e04b0eaf6ba65b0c5b87d2
     Docs: man:fail2ban(1)
   Main PID: 9411 (fail2ban-server)
      Tasks: 5 (limit: 9353)
     Memory: 12.5M (peak: 12.7M)
        CPU: 2.891s
   CGroup: /system.slice/fail2ban.service
           └─9411 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Jul 30 18:32:38 MachadoPC systemd[1]: Started fail2ban.service - Fail2Ban Service.
Jul 30 18:32:38 MachadoPC fail2ban-server[9411]: Server ready
--- client ---
Status
|- Number of jail:    1
|- Jail list:        sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed:    0
| `-- Journal matches: _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 0
   |- Total banned:    0
   `-- Banned IP list:
```

Figura - Evidencia 6 - Fail2Ban jail sshd

```
Terminal - Evidencia 7 - AIDE baseline FULL (sem /mnt WSL) + deteccao

root@MachadoPC:~# cat /etc/aide/aide.conf.d/98_wsl_exclusions
# Excludes WSL/Windows - evita scan de /mnt/c /mnt/d /mnt/f (centenas de GB)
-/mnt$ 0
-/usr/lib/wsl$ 0
-/usr/lib/modules$ 0
-/init$ 0

root@MachadoPC:~# aideinit -y -f
Running aide --init... OK (~96s)
Nota: exclusao de /mnt evita scan de C:/D:/F: no WSL
-rw----- 1 aide_aide 6.1M Jul 30 19:15 /var/lib/aide/aide.db
Start timestamp: 2026-07-30 19:13:39 -0400 (AIDE 0.19.1)
AIDE successfully initialized database.
Number of entries: 22639
End timestamp: 2026-07-30 19:15:15 -0400 (run time: 1m 36s)

root@MachadoPC:~# aide --config=/etc/aide/aide.conf --check
Start timestamp: 2026-07-30 19:15:34 -0400 (AIDE 0.19.1)
AIDE found differences between database and filesystem!!
Total number of entries: 22643
Added entries: 4
Removed entries: 1
Changed entries: 5
Added entries:
Removed entries:
Changed entries:
f =... mci... : /etc/hosts
File: /etc/hosts
End timestamp: 2026-07-30 19:16:34 -0400 (run time: 1m 0s)
... (saida truncada) ...
```

Figura - Evidencia 7 - AIDE baseline FULL (sem /mnt WSL) + deteccao

```
Terminal - Evidencia 8 - Lynis Hardening Index = 69

root@MachadoPC:~# grep -E 'hardening_index|lynis_version' /var/log/lynis-report.dat; echo '--- Hardening index ---'; grep -i 'Hardening index' /var/log/lynis-report.dat
lynis_version=3.1.4
hardening_index=69
--- Hardening index ---
2026-07-30 19:09:36 Hardening index : [69] [#####]
--- top suggestions ---
suggestion[]=LVNIS|This release is more than 4 months old. Check the website or GitHub to see if there is an update available.|-|
suggestion[]=DEB-0280|Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions|-|
suggestion[]=DEB-0810|Install apt-listbugs to display a list of critical bugs prior to each APT installation.|-|
suggestion[]=DEB-0811|Install apt-listchanges to display any significant changes prior to any upgrade via APT.|-|
suggestion[]=DEB-0831|Install needrestart, alternatively to debian-goodies, so that you can run needrestart after upgrades to determine which daemons are u
suggestion[]=BOOT-5180|Determine runlevel and services at startup|-|
suggestion[]=BOOT-5264|Consider hardening system services|Run '/usr/bin/systemd-analyze security SERVICE' for each service|-|
suggestion[]=KRNLL-5788|Determine why /vmlinuz or /boot/vmlinuz is missing on this Debian/Ubuntu system. [/vmlinuz or /boot/vmlinuz|-|
suggestion[]=AUTH-9230|Configure password hashing rounds in /etc/login.defs|-|
suggestion[]=AUTH-9262|Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc or libpam-passwdqc|-|
suggestion[]=AUTH-9282|When possible set expire dates for all password protected accounts|-|
suggestion[]=AUTH-9284|Look at the locked accounts and consider removing them|-|
suggestion[]=AUTH-9286|Configure minimum password age in /etc/login.defs|-|
suggestion[]=AUTH-9286|Configure maximum password age in /etc/login.defs|-|
suggestion[]=AUTH-9328|Default umask in /etc/login.defs could not be found and defaults usually to 022, which could be more strict like 027|-|
--- warnings ---
warning[]=PKGS-7392|Found one or more vulnerable packages.|-|
```

Figura - Evidencia 8 - Lynis Hardening Index = 69

4. Conformidade com a Política AmazonTech

Diretriz		Atendida?
1. Todo serviço ativo com justificativa		SIM
2. Serviços desnecessários desabilitados		SIM
3. Configuração padrão revisada		SIM
4. Acesso remoto endurecido (SSH)		SIM
5. Apenas comunicações necessárias (UFW)		SIM
6. Eventos suspeitos tratados (Fail2Ban)		SIM
7. Integridade monitorada (AIDE)		SIM
8. Auditorias periódicas (Lynis)		SIM
9. Validação após alterações		SIM
10. Evidências registradas		SIM
Resultado	OS CONCLUÍDA - controles Lab 03 implementados e validados	
Documento técnico	Lab03_Redução_Superfície_Ataque_PREENCHIDO.pdf	
Equipe	Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato	